Note de pré-projet – Messagerie souveraine de l'administration

Équipe : Groupe Pegasus — *[à compléter : noms, rôles et compétences de chaque membre]*
Défi : la messagerie souveraine de l'administration · **Licence** : AGPL-3.0

1. Le problème

Faute d'outil officiel, beaucoup d'agents échangent des informations de service sur des messageries grand public, avec leur numéro personnel. Les données sont hébergées à l'étranger, l'administration ne sait pas qui fait partie d'un groupe, et lorsqu'un agent quitte son poste ou perd son téléphone, **personne ne peut lui retirer l'accès** aux conversations de service.

2. Notre réponse

Une messagerie instantanée (web et mobile) **hébergée par l'administration**, construite sur des briques open source reconnues, et renforcée par des contrôles de sécurité que nous avons développés :

- **Chiffrement de bout en bout** avec le protocole Matrix (Olm/Megolm) : le serveur de l'administration transporte les messages sans pouvoir les lire, et refuse tout message en clair.
- **Agents enrôlés seulement** : un administrateur crée le compte ; à la première connexion, l'agent choisit son mot de passe et enregistre un **second facteur** (application TOTP libre, hors ligne, sans SMS).
- **Console de sécurité** : enrôlement, **révocation immédiate sur tous les appareils**, bouton d'urgence « téléphone perdu », habilitations, journal des intrusions.
- **Salons classifiés** : `[DIFFUSION RESTREINTE]` et `[CONFIDENTIEL]`, avec accès réservé aux habilités, déclassement interdit et effacement automatique des messages (30 / 7 jours).
- **Souveraineté** : installation en une commande sur un serveur de l'administration, qui fonctionne même sur un réseau local **sans Internet**.

3. Pour qui, et comment on l'utilise

Acteur	Parcours
Agent	Reçoit identifiant et mot de passe provisoire en main propre → première connexion (mot de passe + TOTP) → échange dans le navigateur ou l'application Element, en individuel ou en groupe
Responsable sécurité	Enrôle, habilite, révoque depuis la console ; suit le journal (connexions refusées, refus du serveur)
DSI / hébergeur	Installe avec `./installer.sh`, garde la main sur les données, applique les mises à jour

4. Ce qui est innovant

Les briques (Synapse, Element, Keycloak) existent ; notre valeur est de les **assembler pour un usage d'État sans aucune dépendance extérieure** et d'ajouter ce qui leur manque pour l'administration : contrôle des habilitations **imposé par le serveur**, révocation en un clic coordonnée entre l'identité et la messagerie, réponse à la perte d'un téléphone, et des **tests de sécurité automatisés** qui prouvent chaque garantie à chaque version.

5. Faisabilité

- **Technique** : prototype fonctionnel, 41 tests automatisés réussis (dont un échange chiffré réel dont le texte est recherché sans succès dans toute la base).
- **Matériel** : un serveur de l'administration (4 cœurs, 8 Go de mémoire, 100 Go de disque) devrait suffire, selon nos estimations, pour un pilote de quelques centaines d'agents.
- **Coût logiciel** : nul (logiciels libres) ; le coût est l'hébergement et l'exploitation.
- **Compétences** : Docker, Python, administration Linux ; notre code reste petit et lisible (module serveur, console, configuration).

6. Feuille de route

Étape	Contenu
1. Pilote (3 mois)	Un ministère, 50 agents ; certificats de l'infrastructure de clés de l'État ; sauvegardes chiffrées ; formation des agents à la vérification des appareils

Étape	Contenu
2. Généralisation	Application d'authentification libre (Aegis ou FreeOTP) recompilée et distribuée par l'administration, puis clés de sécurité FIDO2 ; service de notifications hébergé par l'administration (UnifiedPush) ; envoi des clés aux seuls appareils vérifiés ; haute disponibilité ; audit de sécurité externe
3. Interministériel	Un serveur par ministère, fédérés **uniquement entre eux** (liste blanche) ; annuaire commun
4. Accessibilité	Traduction des applications en langues nationales, proposée directement aux projets Element et Keycloak (contribution aux projets d'origine)

7. Risques et réponses

Risque	Réponse
Faible adoption face aux messageries grand public	Applications familières (Element), enrôlement simple, usage rendu officiel par les services
Agent qui ne vérifie pas ses appareils	Alerte visible dans l'application, formation, puis blocage des appareils non vérifiés
Panne du serveur	Sauvegardes, procédure de reprise, puis haute disponibilité à l'étape 2
Failles dans un composant	Versions figées et suivies, mises à jour régulières, tests automatisés à chaque mise à jour

8. Engagement open source

Niveau **« Étendre et adapter »** : nous utilisons Synapse, Element et Keycloak sans les modifier, nous étendons Synapse par son API officielle de modules et nous publions tout notre travail sous AGPL-3.0. Chaque technologie et sa licence sont listées dans le README.